

研究报告 · 只提出方案，不修改项目

全仓库问题分析 与组件风格统一方案

针对 Next.js 短链接项目，明确哪些问题可以直接处理，哪些必须结合数据库、部署环境或产品规则验证后再实施。

94

src 文件，包括 favicon

11,682

TS / TSX / CSS 文本行

16 页

问题、设计规范与实施路线

核心结论

现有技术栈和基础组件可以保留，不需要全量重写。应先收紧安全与数据契约，再统一基础控件、业务组件和页面布局。单纯调整颜色和圆角，无法解决入口行为不一致及权限策略冲突。

最优先：验证安全配置是否可被匿名读取；确认公开跳转与密码保护的数据库访问边界；修复空密码保护失效；限制用户 URL 的服务端出站访问；评估框架安全更新。

本次交付边界：业务源码、配置和锁文件均未修改。执行了本地安装、静态检查、密码工具验证和构建尝试；新增文件仅为本报告及可重新打印的 HTML。

审查基线：提交 f731048；项目 short-url-next；本地 Node.js 24.15.0 / pnpm 11.7.0。安全审计结果仅代表报告生成时的数据库快照。

01 • 如何理解本报告

- A / 可直接处理：**源码或本地实验已确认，预期行为明确，不需要先改变数据库权限或产品政策。仍须编写针对性回归测试。
- B / 先验证再实施：**代码风险存在，但实际影响依赖 RLS、部署平台、外部服务、历史数据或产品语义。不能把风险描述等同于“线上已被利用”。
- C / 规范提案：**组件、视觉和代码风格建议，需要确认统一规范，并以浏览器截图和交互测试验收。

检查	实际结果与限制
仓库基线	起始与审查结束时，已跟踪文件均无变更。检查 app、components、lib、utils、types 及根配置、部署文档。
依赖安装	<code>pnpm install --frozen-lockfile --ignore-scripts</code> 成功；未更新依赖或锁文件。
TypeScript	<code>pnpm exec tsc --noEmit --incremental false</code> 通过。这不证明未类型化的数据库字段正确。
ESLint	<code>pnpm lint</code> 失败：11 个错误、24 个警告。涉及 any、Effect 中同步 setState、未使用变量及 Hook 依赖。
密码工具实验	原文件转译后在内存中执行。确认空保护密码返回 null hash 且不报错；无效类型通过；bcrypt 相同前 72 字节的不同密码可匹配。
生产构建	<code>pnpm build</code> 编译与类型阶段完成，收集页面数据时因缺少 Supabase URL 中断。存在 middleware 废弃及 Supabase Edge API 警告。
依赖安全审计	<code>pnpm audit --json</code> 返回 129 个告警计数：critical 2 / high 73 / moderate 45 / low 9。不是 129 个线上可利用漏洞。
浏览器与数据库	未运行真实业务页面、登录注册、生产 RLS 或平台集成测试；本地没有 .env.local。视觉结论来自源码，不是已完成截图验收。

优先级定义

P0：潜在密钥泄露、保护边界失效或高危依赖暴露，立即核查。**P1：**明确功能错误、隐私与数据完整性。**P2：**一致性、维护性、体验和性能改善。

02 架构与现有基础 · 第 3 页

03 可直接处理 · 第 4–6 页

04 必须验证 · 第 7–10 页

05 风格与组件 · 第 11–13 页

06 工程规范 · 第 14 页

07 验收矩阵 · 第 15 页

08 实施路线 · 第 16 页

每项均附源码定位或验证条件

02 · 项目的真实结构

模块	当前职责	主要观察
首页 / ShortenForm	用户状态、公告、短链表单；调用 /api/shorten。	共用字段组件，但部分字段未传入；前后端重复产生随机 slug。
用户控制台	客户端拉取本人链接，创建、删除、密码更新。	与 API 创建链路重复；加载时执行删除；查询异常缺少可恢复状态。
管理员后台	全局列表、批量删除、设置、CSV 导出。	角色检查存在；数据库策略是否支持另需验证。设置页约 1,134 行。
跳转 / 密码验证	动态查询链接、过期处理、验证密码、计数。	使用全局 anon client；是否能读取、删除取决于 RLS。密码缺 hash 时直接放行。
认证	Supabase SSR cookie、middleware、登录、注册、邮箱回调。	Actions 有身份检查，但密钥相关读取与注册配置处理不一致。
配置与安全工具	多组设置读取、URL 校验、Turnstile、Safe Browsing、bcrypt。	设置类型和默认值多份；大量内部工具被标记为 Server Action。
UI 基础层	Radix / shadcn 风格 Button、Dialog、Input、Select、Toast。	复用基础较好；业务层反复覆盖配色、间距、动画与状态逻辑。

可以保留的工程基础

- App Router 与 TypeScript strict；API 和 Server Actions 可继续共存，但共享同一业务服务。
- Radix 对话框和菜单提供交互基础；不需要为了“统一”重新实现焦点管理和键盘交互。
- `cn()`、CVA Button variants、CSS 语义颜色变量已经存在，适合继续扩展。
- 用户删除和密码更新显式限定 `user_id`；管理员 Actions 单独检查 `profile.role`。
- 短链成功跳转使用 302 与 no-store 响应头，方向合理；bcrypt 也优于明文密码。
- 已有 LinkFormFields、CopyButton、QRCodeDialog、LoadingButton 等真实复用点。

推荐边界：页面负责布局与交互；业务组件负责领域状态；服务端服务负责校验、权限和写入；数据库约束与 RLS 负责最终保护。不要把“统一组件”扩展成不必要的全仓库重写。

大文件不是独立 bug。只有当设置字段、校验、保存和主题预览互相耦合，或相同领域逻辑多处复制时，拆分才有明确收益。

03 • 明确的功能错误

A01 • P0 选择密码保护，空密码却成功写入

证据： `processLinkPassword` 在验证前执行 `type === 'none' || !password`，直接返回 `{ hash: null }`。本地实验已确认 `six_digit/custom` + 空字符串不报错。跳转与验证接口遇到缺失 `hash` 又按无密码放行。

建议： 先校验类型枚举，只有 `none` 可返回空 `hash`；受保护类型必须有有效密码。读取到“受保护但无 `hash`”的异常记录应拒绝跳转，返回可恢复错误。

回归： 通过 API、Action、更新密码分别提交空密码、未知类型、非六位数字；均不得产生公开保护链接。修复已有异常数据前先备份与统计。

`src/lib/password.ts:77` · `src/app/[slug]/route.ts:33` · `src/app/api/verify-password/route.ts:37`

A02 • P1 Server Action 丢弃密码校验错误

证据： `createLink` 内部只提取 `result.hash`，没有检查 `result.error`。因此不合规密码可能作为空 `hash` 写入；`/api/shorten` 则检查错误，两个入口行为不同。

建议： 写入前调用并检查一次 `passwordResult`；失败时立即返回统一错误结果。不要在 `insert` 对象中隐藏异步 `IIFE`。

`src/app/dashboard/actions.ts:122` · `src/app/api/shorten/route.ts:103`

A03 • P1 首页显示有效期选项，却没有提交有效期

证据： `ShortenForm` 没有 `expiresAt` 状态，也没有向 `LinkFormFields` 传 `setExpiresAt`；JSON 请求不包含 `expiresAt`。用户选择 1 小时、7 天或永不过期，不影响最终 API 请求。

建议： 创建入口共享完整表单模型，确保有效期字段参与提交。用显式模式表达 `default / permanent / duration`，避免 `undefined` 同时表示“默认”和“永久”。

`src/app/shorten-form.tsx:63` · `src/app/shorten-form.tsx:221` · `src/components/link-form-fields.tsx:97`

A04 • P1 默认过期时间和永久模式没有统一契约

证据： API 缺 `expiresAt` 会应用 `defaultExpiration`；Action 缺 `expiresAt` 直接写 `null`。API 中“永久”若提交空值，也会回退到站点默认。Action 直接调用则可绕过默认时长。

建议： 服务端共享有效期解析器；明确区分未提供、永久、相对时长、绝对时间，并拒绝无效或已过期时间。基于创建时刻计算时长，避免在表单打开时提前消耗有效期。

`src/app/api/shorten/route.ts:92` · `src/app/dashboard/actions.ts:120` · `src/components/link-form-fields.tsx:97`

04 · 数据契约不一致

A05 · P1 CSV 导出使用不存在于当前契约的字段

证据：列表和 README 使用 slug / clicks；导出却读取 short_code / visits，且包含未定义的 title / description。按仓库文档表结构，短码列为空、点击次数始终为 0。

建议：按实际 Link 类型明确 select 和 CSV 列，使用 slug / clicks。导出列统一做引号、换行和公式前缀防护；历史部署若扩展过表结构，先核对列名。

src/app/api/admin/export/route.ts:57 · src/app/api/admin/export/route.ts:61 · README.md:64

A06 · P1 管理员列表丢失密码状态

证据：服务端 normalized 对象未保留 password_type，共享 Link 类型也未声明它。LinkCard 接收到的管理列表无法正常显示是否受保护及“修改/添加密码”文案。

建议：建立统一 LinkSummary 类型，仅包含界面需要的字段，保留 password_type，绝不传 password_hash。

src/app/admin/links/page.tsx:45 · src/app/dashboard/links-table.tsx:30 · src/app/dashboard/link-card.tsx:285

A07 · P1 防递归和域名拦截使用字符串包含判断

证据：Action 使用 url.includes(host)，外站查询参数里出现本站域名也被拒绝；API 不做同一检查。Action 另有硬编码 malware.com/phishing.site 子串黑名单。

建议：通过 URL 解析后比较标准化 origin/hostname 与受信任站点配置；移除平行的示例黑名单，统一使用域名匹配逻辑。

src/app/dashboard/actions.ts:54 · src/app/dashboard/actions.ts:95 · src/app/api/shorten/route.ts:51

A08 · P1 短链生成、复制、展示和二维码使用不同域名

证据：复制使用 window.location.origin；LinkCard/二维码使用 NEXT_PUBLIC_BASE_URL，缺失时回退到 short.link。预览域名、主域名或环境配置不同，会得到不同 URL。

建议：定义站点规范域名来源，集中 buildShortUrl；预览环境策略明确后，再让四处统一使用该规则，去掉虚构域名兜底。

src/components/copy-button.tsx:13 · src/app/dashboard/link-card.tsx:66 · src/app/dashboard/link-card.tsx:74

A09 · P1 输入缺少服务端类型和边界校验

证据：request.json/FormData 强制断言后直接使用；slug 无长度上限与路由保留词校验，expiresAt 无解析验证。合法 slug 如 login/dashboard 会撞已有路径。

建议：使用共享 schema 校验 URL、slug、passwordType、时长与 token；统一 trim/长度/整数限制；拒绝保留路径。非法 JSON 应返回 400，而非未捕获异常。

src/app/api/shorten/route.ts:12 · src/lib/url-validation.ts:26 · src/app/dashboard/actions.ts:38

05 · 不必等待线上研究的改进

A10 · P1 查询失败被当作空数据，异步失败缺少恢复

控制台只读取 data，错误时展示空列表；加载函数没有完整 catch/finally。删除、批量删除、密码更新和设置保存也有直接 await 后重置状态的路径，异常时可卡住 pending。

建议：区分 loading / success-empty / success-data / error / session-expired；异步操作在 finally 清理状态；失败保留表单内容，并提供重试。

src/app/dashboard/page.tsx:29 · src/app/dashboard/link-card.tsx:76 · src/app/dashboard/links-table.tsx:78 · src/app/dashboard/reset-password-dialog.tsx:68 · src/app/admin/settings/page.tsx:296

A11 · P2 设置类型、默认值与配置读取重复

types/settings、lib/site-config、dashboard/settings-actions 和设置页各自保存类型/默认值；expiredDays 存在 30 与 90 的差异。getCachedSiteConfig 实际只是别名，没有缓存实现。

建议：合并到一个类型与默认值来源，逐项 merge 旧配置并做运行时验证。内部读取与公开 DTO 分离；确需缓存后再设计失效策略，不跨用户缓存认证数据。

src/types/settings.ts:102 · src/lib/site-config.ts:54 · src/app/dashboard/settings-actions.ts:8 · src/app/admin/settings/page.tsx:56

低风险事项	可直接安排的内容	验收要求
A12 · P2 工程清理	移除 lint 标出的未使用导入；用 unknown/明确类型替代 any；补正确 Hook 依赖。LoadingProvider 需要调整状态来源，不能只关闭规则。	lint 零错误，warning 逐项归零；不改变业务行为。
A13 · P2 语义与可访问性	根语言改为 zh-CN；slug Label htmlFor 与 Input id 对齐；给返回、移动端登出、管理入口和多选控件补可访问名称。	键盘、读屏与标签点击测试；图标 tooltip 不代替 aria-label。
通知与文案	统一“登录”、创建链接命令、复制成功与失败提示；创建弹窗不再使用“保存更改”。移除调试日志中的完整 URL/用户数据。	错误类型一致；敏感 URL 的 query 不写普通日志。
文档与示例	README 技术栈更新为 Next 16；说明 BASE_URL/SITE_URL；消除 SQL 中重复 create profiles，整理初始化步骤。	全新测试库可从文档完成初始化；不直接改生产策略。

可直接改的边界：字段、标签、错误处理和类型整理不需要访问生产库；主题色、页面布局 and 核心加载机制仍要做截图/交互回归。没有“直接改 = 一次全仓库格式化”的必要。

06 • 数据库安全边界

B01 • P0 安全配置存在匿名泄露路径

源码确认：README 对 settings 配置 USING(true) 公开 SELECT，同一 security JSON 包含 Turnstile Secret 与 Safe Browsing API Key。getSecurityConfig 无认证并返回整个对象，文件级 use server 将它注册为 Server Action。本地编译 manifest 已确认 exportedName 为 getSecurityConfig。

尚待验证：生产是否照文档执行了策略、security 行是否存有真实密钥，以及 Action 实际调用响应。不能仅靠 getPublicSecuritySettings 的脱敏返回证明安全。

验证：在隔离测试库，匿名用 anon key 请求 security 行；匿名调用编译后的 Action；普通用户再次测试。期望都不能获取任何私密字段。

修复方向：公开配置与私密配置分离；内部读取使用 server-only 模块而不是公开 Action；私密设置需管理员权限或受控服务端读取。若确认已泄露，先撤销公开路径并轮换密钥。

README.md:202 / :226 · src/lib/site-config.ts:1 / :235 · .next/server/server-reference-manifest.json (编译产物证据)

B02 • P0 公开短链功能与现有 RLS 文档冲突

源码确认：跳转、验证使用 anon client；README links SELECT/INSERT 仅允许 auth.uid() = user_id，匿名没有满足条件的身份。文档也缺少普通用户 UPDATE、管理员全局链接 SELECT/DELETE 策略。允许 user_id 为 NULL 不等于允许匿名插入。

两种风险：严格照文档，匿名创建/跳转与更新密码可能失败；为了修好而开放 links SELECT，则目标 URL、邮箱、hash 可能被直接读出，密码验证形同虚设。

验证：导出 pg_policies、实际 schema、授权和 RPC；以匿名/用户 A/用户 B/管理员执行权限矩阵。保护链接目标不能被匿名 REST 查询绕过。

修复方向：优先采用最小返回字段的受控服务端解析/RPC；公开创建也走验证服务。service role 仅放服务端，使用前必须显式执行权限和业务校验。

README.md:129 / :134 / :139 · src/lib/supabase.ts:6 · src/app/[slug]/route.ts:13 · src/app/dashboard/actions.ts:209

不要直接给 links 全表公开读权限，也不要全部请求换成 service role 来“解决功能问题”。先建立最小权限矩阵，并使用测试库验证。

07 • URL 与密码验证风险

B03 • P0 URL 可用性检测缺少 SSRF 防护

服务端对用户 URL 发 HEAD，并自动 follow 重定向；没有私网/环回/链路本地/IPv6 地址限制、DNS 解析检查和逐跳验证。公开 /api/test-validation 还可直接触发检测并返回黑名单配置。

验证：只在隔离网络测试 localhost、私网、IPv6、域名到私网的重定向和 DNS 变化；用受控端点观察出站访问。不要探测真实云元数据或生产内网。

方向：所有入口强制 HTTP(S) 与地址限制，逐跳验证，配出站网络策略；关闭或管理员保护诊断路由。URL schema 与网络目标验证不能被 skipAllChecks 绕过。

src/lib/url-validation.ts:98 / :103 / :106 / :151 • src/app/api/test-validation/route.ts:5

B04 • P1 失败次数限制依赖公开表、IP 与非原子操作

password_attempts 文档允许公共读取和插入，可能暴露 IP/slug/时间，也允许伪造记录消耗他人额度。接口信任 x-forwarded-for；count 与 insert 分开，并发可绕过 5 次限制，查询错误也未处理。

验证：确认反向代理会覆盖外部 IP 头；多并发错误请求是否严格受限；尝试表是否可匿名读写；数据库异常是否 fail-open。

方向：私密尝试表，服务端原子限流/RPC；按可信 IP 与 slug 组合限流，另加全局速率控制；设置最短保存周期和定时清理。

README.md:115 / :120 • src/app/api/verify-password/route.ts:9 / :44 / :63

B05 • P1 自定义口令 128 字符与 bcrypt 72 字节不匹配

本地确认：两个口令的前 72 个 ASCII 字节相同，后缀不同，bcrypt.compare 仍返回 true；中文会更早达到字节上限。

为什么先验证：限制到 72 字节或升级算法会影响已有链接。需要统计历史类型/长度政策，并设计兼容验证策略。

方向：新口令按 UTF-8 字节长度限制或使用版本化哈希方案；旧 hash 保留兼容验证。不要无迁移地预哈希全部历史密码。

src/lib/password.ts:45 / :64 • src/components/link-form-fields.tsx:394

B06 • P1 注册配置和外部安全服务存在 fail-open

缺 service role 时 signup 不检查关闭注册/Turnstile 配置；启用但缺 Secret 时也跳过验证。设置读取异常回退到开放默认值；Safe Browsing 超时/API 错误被标记 isSafe:true。

验证：移除密钥、断网、403、超时分别测试。明确“安全服务不可用”是拒绝、排队还是管理员允许降级；检查 Supabase Auth 自身注册设置和验证码，不能只防站内 Action。

src/app/login/actions.ts:54 / :88 • src/lib/site-config.ts:31 • src/lib/safe-browsing.ts:294

08 · 产品语义必须明确

问题	源码观察	验证与决策
B07 · P1 过期与自动清理	跳转、验证页、密码接口和控制台加载都直接删除过期数据；autoCleanExpired/expiredDays 没有对应执行器。设置关闭也无法阻止这些删除路径。	定义过期≠删除，是否保留统计/审计/恢复；明确保留天数以什么时刻为基准。对存量数据先备份，再通过定时任务执行清理。
B08 · P1 统计开关与异步计数	enableClickStats 仅控制部分 UI；跳转和密码成功仍调用 RPC。RPC .then 未 await，在 Serverless 响应后可能未完成；公开 RPC 也可被刷计数。	确定开关表示“隐藏”还是“停止采集”；在实际平台压测点击与计数差异。采用 await、平台支持的后台延续或队列；不要假定本地 then 等于可靠执行。
B09 · P1 维护模式	主要通过客户端遮罩；API/创建 Action 不统一检查维护配置，直接请求不受遮罩限制。	决定维护时是否停止创建、编辑、注册、跳转；按矩阵补服务端门禁。管理员绕过只由服务端角色判断。
B10 · P1 设置保存与配置加载	7 组设置顺序 upsert，中途失败会部分保存；服务端无完整参数校验。getSettings 不 merge 单组旧字段默认值。	故障注入验证部分更新；以事务/RPC保证一致性，增加版本/更新时间防覆盖。配置 schema 与旧配置迁移先确认。
B11 · P2 列表与导出规模	用户、管理员和导出均 select('*') 且无分页/range。受 Supabase max rows 配置影响可能只返回前若干条，界面却像完整列表。	用超过部署行数上限的数据验证；确认查询索引和 count。实施游标分页、服务端筛选、分页/流式导出，再评估虚拟化。
B12 · P2 密码编辑权限	管理员列表也显示 ResetPasswordDialog；更新 Action 明确限定本人 user_id。管理员修改他人链接时可能更新 0 行却收到 success。	确认管理员是否应能改他人密码；若不允许，隐藏该操作；若允许，单独管理员 Action。所有 update/delete 都应验证受影响行数。

过期: src/app/[slug]/route.ts:26 · src/app/dashboard/page.tsx:49
计数: src/app/api/verify-password/route.ts:76 · src/app/[slug]/route.ts:39
维护: src/components/maintenance-guard.tsx:15 · 设置: src/app/admin/actions.ts:191
分页: src/app/admin/links/page.tsx:24 · src/app/api/admin/export/route.ts:24
编辑: src/app/dashboard/link-card.tsx:307 · src/app/dashboard/actions.ts:214

额外核对: is_no_index 被保存，但跳转路由不读取，也未设置 X-Robots-Tag；普通 Action 未提交时反而写 false，与表默认 true 不同。需明确该选项到底保护哪个资源，不能只在数据库增加字段。

09 • 运行环境不能只靠静态检查

B13 • P0 框架与依赖安全更新

当前 next 16.0.10, react/react-dom 19.2.1。审计快照给出 2 critical、73 high、45 moderate、9 low。Next 有 Windows 托管 RCE、AVIF Image API RCE、Server Actions DoS 与多类 middleware bypass 告警；不少告警依赖未启用的特性，不应全部视为当前可利用。

建议：按实际部署 OS、Image API、Server Actions、App Router 与缓存特性做可达性分级；在升级分支验证框架、React、PWA 兼容性。此次 critical 公告列出 Next $\geq 16.3.3$ 的修补范围，但落地时重新审计选择受支持版本，不机械写死最低号。

GHSA-p293-qw3h-jr36 (Windows)

GHSA-2xp9-vwfh-vxw4 (AVIF)

GHSA-h25m-26qc-wcjf (RSC/DoS)

B14 • P1 PWA 缓存需要保护跨账号隐私

next-pwa 开启前端导航与激进缓存。构建生成的 sw.js 包含 GET /api 的 NetworkFirst 缓存，以及非 API 的 pages、pages-rsc 缓存；没有显式排除 admin、dashboard、认证回调、密码验证和短链资源。

验证：生产模式下账号 A 登录、查看列表、退出，账号 B 登录或离线访问，再检查缓存、返回内容与跳转；验证密码变更、过期、维护模式是否被旧响应遮蔽。

方向：敏感接口/页面用 NetworkOnly，按需只缓存公开静态资产；登出清理敏感缓存。生成的 SW 不能因为 HTTP no-store 就假定 Cache API 不会保存。

next.config.ts:9 • public/sw.js (本次构建生成并被 .gitignore 忽略)

B15 • P1 Cloudflare 部署配置并未形成 SSR 构建链路

pages:build 实际运行 wrangler pages deploy；wrangler.toml 指向 public。仓库未配置 Next Cloudflare 适配器生成 Worker/SSR 输出，直接部署静态资源不能证明 API、Actions、动态短链可用。

验证：先确定生产目标为 Vercel、Node 还是 Cloudflare Workers；如保留 Cloudflare，按当前受支持适配器完成隔离预览并测试认证 cookie、Actions、跳转和平台后台任务。

package.json:9 • wrangler.toml:4 • src/utils/supabase/middleware.ts:10

构建与认证中间件补测

本地 build 因环境变量缺失中断，不是确认的生产构建缺陷。补齐测试库配置后复跑；处理 Next 16 middleware→proxy 迁移与 Supabase SSR getAll/setAll cookie API 一致性，验证多 cookie 刷新、长会话和 Edge/Node 运行时。

10 • 全仓库视觉基础

保留现有中性基调和可配置品牌色，统一“语义”而非把所有元素染成同一种颜色。后台优先密度、扫描效率和稳定操作。

维度	当前不一致	建议统一规范
颜色	CSS 有 primary/destructive，但业务层出现 red-600、gray-500、purple-500、green-500 等独立覆盖。	使用 background/card/muted/primary/destructive；增加 success/warning/info 及各自 foreground。品牌色只用于主命令、选中与关键链接。
圆角	根 radius 10px；Card rounded-xl；业务列表 xl，Dialog lg，维护模式 2xl。	控件 6px、卡片与弹窗 8px；圆形仅头像/色块/徽记。作为迁移后的目标，不直接全局替换现有样式。
字号与字重	后台标题 3xl、管理员首页 4xl/5xl；tracking-tight 多处使用。	后台页标题 24px/600，区块 18px/600，正文 14px，辅助 12px；行高 1.5。字距 0，标题不靠缩紧来适配。
字体	Lexend/vivoSans/Geist 混合，本地多个字重，另从 Google 构建加载。	确认一套中英文字体与 mono；只保留实际使用字重。移除字体前测字宽、布局、版权与构建可用性。
间距与宽度	控制台 max-w-6xl，设置 max-w-4xl；顶部 padding 随页面差异很大。	4px 基础尺度；控件间距 8/12，字段 16，区块 24；后台容器建议 1152px，移动端边距 16px。
尺寸	Button h-8/9/10 与页面覆盖并存；OTP 存在 48px×6，加边距后易紧张。	桌面控件 36px；触屏主要操作 44px；图标 16/20px；OTP 用六列等宽、明确 gap 与 min-width:0。
阴影与背景	卡片 hover 大阴影、渐变、全局拼图和维护模糊装饰同时存在。	后台默认不加装饰背景；常态轻边框；菜单/弹窗才用明显阴影。保留品牌背景时限定在公开页面。
动画	CSS btn-press、ActionScale、自定义动态图标和卡片 scale 叠加；缺 reduced-motion 策略。	微反馈 120–180ms；转场 180–240ms；不替换命令文字、不缩放整张业务卡。集中遵守 prefers-reduced-motion。

背景 / 中性

主命令 / 示例品牌色

成功

警告

危险

信息

以上色块是规范示意，并非要求将当前品牌色改成绿色。深浅主题、动态品牌色都需测正文 4.5:1、大字与非文本关键控件 3:1 对比度。

src/app/globals.css:49 · src/components/ui/card.tsx:10 · src/components/theme-color-provider.tsx:17 · src/lib/color-utils.ts:70

11 · 组件一致性落地表

保留 / 收敛对象	统一行为	实施边界
Button / LoadingButton	一个 variants 来源；loading 固定尺寸、aria-busy、防重复提交；危险操作只用 destructive。默认图标 lucide，不靠文字变箭头。	ui/button、loading-button；不在业务页面重复红色按钮配方。
IconButton 小型公共封装	统一 icon size、tooltip、aria-label、touch target、disabled/focus；标题和命令名称保持稳定。	先替换返回、复制、更多、登出；不是另造一整套按钮系统。
FormField 错误与标签	标签、输入 id、说明、错误 id，aria-describedby/invalid 一致；表单保留服务端错误并定位字段。	在 Input/Label 上薄封装。字段 schema 不混入 toast 实现。
LinkFormFields	受控完整模型：URL、slug、expiration、password；明确高级选项展开命令，所有入口提交同一字段。	移出取配置/随机码副作用；父层或公共 hook 负责配置。复用字段，不复用页面布局。
PasswordFields	none / six_digit / custom 共用校验、OTP 布局与口令显示控制；创建、修改、访问验证语义不同。	复用输入与格式规则，访问验证保留独立流程；不复制三套 OTP。
ConfirmDeleteDialog	单条、批量、过期清理共用确认样式；显示数量与对象，pending 阻止重复提交；失败保留弹窗。	LinkCard、LinksTable、旧 DeleteLinkDialog 与 window.confirm 收敛。
LinkCard / LinkList	LinkSummary 类型；展示 URL、过期、保护、统计；共享权限模型，避免管理视图出现不可执行操作。	LinksTable 实际是卡片网格，命名应忠实于实现；添加密集表格前先确认规模需求。
PageHeader / Container	页标题、描述、返回与动作区统一；移动端 actions wrap；邮件/URL min-width:0、合理换行。	用户后台和管理员三页优先采用。
AsyncState / Empty / Toast	区分空数据、加载和失败；路由加载优先 Next loading/Suspense，提交加载用按钮；不依赖各页面手动关闭全局遮罩。	SmartLoading / LoadingProvider 分步替换，先覆盖导航失败与同路由跳转。
CopyButton / QRCodeDialog	共享 URL 构建；复制失败可见；下载提供真正 quiet zone 与固定尺寸；二维码白底作为可扫描性例外保留。	二维码不要为了深色主题改成低对比；实际手机扫码验证。

不建议抽象的内容

不把所有页面变成通用配置渲染器，不为单次布局创建“万能 Card”，不重新实现 Radix Dialog。新增公共组件必须至少消除两处实际重复，且 props 应描述语义而非堆砌 className 参数。

12 · 页面和状态必须一起统一

页面	建议整理	必须覆盖的状态
首页	保留实际短链工具作为首屏；减少嵌套预览框；高级选项显式展开；统一结果条、复制、URL 换行。	匿名/登录、公开创建开关、配置加载失败、验证码、各有效期、密码保护、成功结果、长域名。
登录 / 注册	用熟悉的分段模式或清晰步骤；按钮名称固定；复用认证字段和错误区。713 行文件按流程拆分，暂不改变注册政策。	关闭注册、需要验证码、已注册邮箱、邮件确认开/关、回调错误、登录失败、低高度键盘弹出。
用户控制台	PageHeader、统一动作组；链接状态可扫描；错误不显示为“还没有创建”。查询不再承担隐式清理。	加载、空、失败、session 过期、删除失败、密码更新、过期记录、超长 email、管理员入口。
管理员首页	收敛巨大标题和装饰 hover；入口排列紧凑；未实现的入口不要伪装可点击；保持后台信息密度。	普通用户禁止访问、管理员导航、加载失败、移动端菜单、键盘 focus。
全局链接管理	统一 LinkSummary；保护状态与批量选择；以权限决定操作；分页、搜索和筛选经规模验证后实施。	匿名/本人/他人链接、批量删除 0/1/多条、权限失败、分页选择语义、部分失败。
系统设置	按站点/链接/外观/安全/数据/维护分区；使用未加外框的区块，设置项不套多层卡片；可考虑分区导航与保存条。	旧配置缺字段、密钥遮罩、未保存提醒、保存失败与部分写入、主题预览撤销、清理确认。
密码访问页	稳定宽度和六列 OTP；与创建/修改输入样式一致；输入错误与剩余次数靠近字段；明确不存在/过期状态。	320px、200% 缩放、验证码/口令、5 次失败、限流、网络异常、链接失效、成功跳转。
维护 / 全局布局	后台去除拼图装饰；维护用独立状态页，不覆盖仍可交互的后台内容；footer wrap，避免长作者名称挤压。	管理员绕过、非管理员、键盘焦点不穿透、长维护消息、长 footer、深色主题。

截图验收基线

至少使用 320×568、390×844、768×1024、1440×900；浅色/深色各一套。测试系统 reduced-motion、200% 缩放和触屏操作。长 URL、长 slug、长邮件、最长按钮文案都要覆盖。

截图应检查：水平溢出、对话框超出可视高度、toast 遮挡动作、OTP 裁切、hover 引起位置漂移、隐藏按钮无法键盘发现。Dialog 内容区设置可用视口 max-height 与独立滚动，焦点返回触发器。

当前视觉风险而非已确认截图缺陷：OTP 固定宽度、动作组不可换行、结果 URL 缺 min-width:0/break-all、footer 无 wrap 等需真实渲染后确认。报告不把源码推断包装成已复现的 UI 故障。

13 · 仓库规范提案

规范	建议执行规则
格式化	新增统一 formatter 与 EditorConfig，缩进、引号、分号以一次确认的规则为准。推荐 TS/TSX 2 空格、双引号、分号；若团队偏好当前业务风格，保持一致即可。格式化提交与功能提交分开。
命名	文件 kebab-case；React 组件 PascalCase；函数/变量 camelCase；DB 数据保留 snake_case，边界 DTO 明确映射。LinksTable→LinkList 等重命名不要与安全修复混在一起。
导入	React/Next → 第三方 → 公共 UI → 领域组件 → 服务/types → 样式；使用 type-only import；保持 @/ 别名，禁止业务组件反向从页面导入公共类型。
类型	一个 PasswordType、LinkSummary、Settings、ActionResult 来源；生成 Supabase Database 类型，查询指定列。unknown 在边界校验后收窄，禁止用 as any 绕过配置。
服务端边界	仅真正可供客户端调用且做权限检查的函数置于 use server Action 文件；内部配置、数据库访问、密码与安全服务用 server-only。不要把“在服务端使用”混同于“暴露 Server Action”。
创建业务	API 与 Action 共享服务：输入解析 → 维护/权限 → 限流/验证码 → URL/slug 安全检查 → 有效期/密码 → 写入。两者只负责 HTTP/FormData 适配与错误输出。
权限	沿用 requireAuth，增加真实的 requireAdmin 消除重复角色查询；数据操作仍保留 ownership 条件。服务端检查与 RLS 各自测试，不以 middleware 代替数据权限。
错误结果	统一可判别联合：ok:true/data 或 ok:false/code/message/fieldErrors。已知失败映射中文消息，未知失败给 requestId；不向前端直接返回数据库内部 error.message。
日志	结构化 level/event/requestId；URL 去敏 query、密码/token/key 禁止输出；移除彩色/表情调试日志和重复横线日志，外部错误做归类。
清理与重试	计时器在 finally/卸载时释放；外部请求明确超时。重试只用于可重试错误和幂等操作，禁止直接重试创建写入造成重复数据。

建议目录职责，而非立即移动全仓库

components/ui 保留基础；components/links 收纳表单、列表与链接操作；lib/server 放内部服务和配置读取；types 放领域 DTO 与数据库类型；app/**/actions.ts 只做公开 Action 适配。建立实际复用后再搬迁，不批量重排路径。

质量门禁

建议 CI 固定 Node/pnpm、frozen lock 安装，依次跑 formatter check、lint、typecheck、单测、隔离配置 build、关键 E2E 与依赖审计。新增 schema/测试工具应单独审视依赖，避免为了整理引入过重框架。

14 • 修复前后如何证明正确

领域 / 对应项	测试输入或场景	预期结果
秘密配置 B01	匿名/普通用户：直接 REST 查 security，调用 getSecurityConfig Action；管理员读取公开与私密设置。	匿名与普通用户永不收到 secret/key；管理员仅从受保护路径获取；日志和客户端 bundle 无秘密。
RLS / 所有权 B02/B12	匿名、A、B、管理员分别执行 SELECT/INSERT/UPDATE/DELETE；公开链接、密码链接各一套。	公开跳转可用，但目标/hash/邮箱不能批量读取；A 不可更新 B；管理员权限与产品政策一致。
密码保护 A01/A02/B05	none、空、错误类型、6 位数字、5/7 位、128 字符、多字节、相同 72 字节前缀；两入口与密码更新。	无效值返回字段错误；受保护链接不能失去 hash；历史 hash 兼容策略明确。
有效期 A03/A04/B07	默认、永久、1 小时、自定义、非法日期、过去时刻；默认时长非 0；表单停留较久再提交。	首页与 Action 同义；服务端使用创建时刻；到期拒绝访问；删除符合保留政策。
URL / slug A07/A09/B03	外站 query 含本站域名；保留 slug；非法 JSON；私网/IPv6/重定向；随机 slug 冲突。	结构校验统一；内网不能访问；自定义冲突 409；随机冲突有限重试且不覆盖数据。
限流 / 验证码 B04/B06	并发密码失败；伪造 forwarded 头；配置加载失败；token 重放/过期；匿名创建洪峰。	限流原子且记录私密；可信 IP；一次性 token 不被两次验证消费；安全降级政策可观测。
列表 / 导出 A05/A06/B11	超过服务端最大返回行数；保护链接；非 0 点击；引号/换行/公式前缀；分页批量选择。	总数与导出一致；slug/clicks 正确；密码类型保留而 hash 不出现在浏览器数据。
配置与维护 B09/B10	保存第 N 组故障、两管理员同时改；旧配置缺字段；开启维护后直接调用 API。	配置不部分更新或明确报告版本；服务端门禁符合维护政策；配置错误不静默开放。
PWA / 平台 B08/B14/B15	A→登出→B；离线读后台；过期/密码变更；Serverless 大量 302；部署预览完整流程。	无跨账号敏感缓存；安全状态及时生效；计数符合定义；API/Actions/cookie 在平台有效。
统一 UI C	四档视口、深浅色、reduced-motion、200% 缩放；只键盘操作；长内容与错误状态。	无水平溢出/遮挡；focus 可见；按钮有名称；弹窗可滚动；视觉 token 与状态一致。

工具建议：纯逻辑测试使用轻量单测框架；Supabase 本地/隔离库验证 RLS；Playwright 跑真实浏览器状态与截图；压力/出站测试限隔离环境。现仓库没有自动化测试脚本、正式 SQL migrations 或 CI 工作流。

15 • 建议实施顺序

阶段	范围	完成条件
阶段 0 先核查	B01/B02 配置秘密与 RLS；B03 SSRF；B13 依赖实际暴露；备份 schema/策略与历史数据。暂时限制公开诊断路由与危险出站能力。	秘密不可匿名读取，保护不可 REST 绕过；形成真实权限矩阵和升级验证分支。
阶段 1 修明确错误	A01–A09 密码、两创建入口、有效期、CSV、LinkSummary、URL 构建、输入 schema；完成错误状态处理。	两入口同一服务与契约；领域测试通过；不再出现受保护但无 hash 的新记录。
阶段 2 确认产品规则	B04–B12 限流、注册降级、哈希兼容、保留策略、统计、维护、设置事务、管理员编辑与分页。	规则书面明确；隔离库/平台矩阵测试通过；迁移与回滚方案可执行。
阶段 3 统一控件	确认第 11 页 token；Button/IconButton、FormField、PasswordFields、删除确认、反馈与异步状态。	组件目录与状态样例齐全；深浅色和键盘回归；禁止新增业务硬编码样式配方。
阶段 4 统一页面	先用户/管理员后台，再首页、登录、验证、维护与 footer；拆设置页和登录流程；删除证实无用的组件/资产。	四档视口与完整状态截图过审；真实扫码、登录回调和操作路径回归通过。
阶段 5 质量门禁	格式化与命名独立提交；CI、测试、schema migrations、配置说明；复测 PWA 与实际部署。	lint/typecheck/build/test 达标；锁文件与环境可复现；上线有回滚与监控。

依赖关系和变更纪律

- 先解决秘密读取和保护边界，再调整 RLS；只改某一条策略可能造成新泄露。
- 先定有效期、统计和清理语义，再统一表单、设置文案和后台状态。
- 先定 LinkSummary 和 URL 构建，再收敛列表、复制、二维码和导出。
- 安全修复、功能修复、组件迁移、纯格式化分开提交，方便评审和回滚。
- 共享基础组件变动需扩大回归范围；单个文案或 label 修改保留窄范围测试。

本次明确未执行

未修改业务代码、RLS、数据库记录、依赖版本或锁文件；未访问生产环境、轮换密钥、执行清理；未声称真实页面的视觉截图或线上流程已验证。依赖安装和构建只生成被忽略的本地产物。

交付： reports/linkflow-review.pdf 为阅读版； reports/linkflow-review.html 为可打印源文件。后续可直接以本报告问题编号作为任务或 PR 标识，逐项追加验证证据。

结论：先修安全和数据一致性，再收敛组件与页面。现有仓库具备继续演进的基础，重点是建立统一的输入、权限、状态和视觉规范，而不是一次性推倒重做。